

Experiment 4: Configure a tool to monitor login/authentication attempts and automatically ban IPs that fail repeatedly to prevent brute force attacks.

Fail2Ban is an open-source intrusion prevention tool used mainly on Linux systems to protect servers from brute-force attacks and unauthorized access attempts.

It works by monitoring system log files (such as SSH authentication logs) and detecting repeated failed login attempts from the same IP address. When a suspicious number of failures is detected, Fail2Ban automatically blocks the attacker's IP address by adding firewall rules.

Procedure:-

Get Root Privilege in ubuntu VM

`sudo su`

1. In Ubuntu VM

`sudo apt install fail2ban`

2. Enable SSH on Ubuntu

`sudo systemctl status ssh`

3. Configure fail2ban

```
sudo cp /etc/fail2ban/jail.conf /etc/fail2ban/jail.local
```

4. Edit

```
sudo nano /etc/fail2ban/jail.local
```

5. [sshd]

```
enabled = true
```

```
port = ssh
```

```
maxretry = 3
```

```
findtime = 600
```

```
bantime = 600
```

6. Restart fail2ban

```
sudo systemctl restart fail2ban
```

7. Now go to kali and check the following path exists:

```
cd /usr/share/wordlists
```

Then if you are finding rockyou.txt.gz file, then unzip the file by using below command.

```
gunzip rockyou.txt.gz
```

After unzipping we will get rockyou.txt file.

8. Simulate Bruteforce attack in kali linux vm

```
hydra -l ubuntu -P /usr/share/Wordlists/rockyou.txt ssh://  
<UBUNTU_IP>
```

9. Observe ban in Ubuntu

```
sudo fail2ban-client status sshd
```

you should see

Banned IP list: KALI_IP

10. Check Logs in ubuntu

```
tail -f /var/log/auth.log
```

11. Now in ubuntu VM—unban the ip

```
fail2ban-client ser sshd unbanip <kali linux ip>
```

After unbanning the ip, go to kali linux vm and try connecting through SSH protocol

```
ssh ubuntu@<ubuntu-ip>
```

Then you are able to connect to ubuntu vm through ssh(because kali ip is unbanned..)

Fail2ban Working:

1. PatternDetection

It uses predefined filters (regular expressions) to detect suspicious activities like repeated failed login attempts.

2. Trigger Condition

If the number of failed attempts from the same IP exceeds a configured limit (maxretry) within a certain time (findtime), Fail2Ban considers it an attack.

3. Automatic Ban

Fail2Ban then adds a rule to the system firewall (iptables, nftables, or ufw) to block the attacker's IP for a specific duration (bantime).

Key Features of Fail2Ban

- Protects against SSH brute-force attacks
- Automatically blocks malicious IP addresses
- Monitors multiple services (SSH, FTP, Apache, Nginx, etc.)
- Uses log file analysis
- Works with iptables, nftables, or firewalls
- Highly configurable and lightweight

Result:

The Fail2Ban tool successfully detected repeated failed SSH login attempts generated by the Hydra brute-force attack from the Kali Linux machine. Once the number of failed attempts exceeded the configured threshold, Fail2Ban automatically blocked the attacker's IP address using firewall rules. As a result, further SSH login attempts from the attacker system were denied, demonstrating the effectiveness of Fail2Ban in preventing brute-force attacks.

Conclusion:

Fail2Ban is a powerful security tool that enhances server protection by monitoring authentication logs and automatically blocking malicious IP addresses attempting repeated login failures, thereby preventing brute-force attacks.